

TRAINING @ FORREST.ONE

Session 3 of 12

Network Fundamentals + CompTIA Security+ SY0-701

Network Services & the Attack Surface

Ports, protocols, documentation, monitoring and recovery, then the core services an attacker can reach.

NETWORK

PORTS

OPERATIONS

SERVICES



Where Session Three goes

- **Sessions 1 and 2** models, addressing, switching and architectures
- **Today** the operations that keep a network running, and the services on it
- **Chapters 1 to 2** well-known ports, traffic types, documentation and agreements
- **Chapters 3 to 5** life cycle, controlled change, monitoring and resilience
- **Chapter 6** the core services: addressing, names, time and remote access
- **The foundation closes** from Session 4 the Security+ core begins
- **The question to hold** what does this service let an attacker do?



SESSION OBJECTIVES

By the end of this session you will be able to

- **Read a port number** and say what the service behind it lets an attacker do
- **Compare plaintext and encrypted services** FTP and SFTP, Telnet and SSH, HTTP and HTTPS
- **Describe the traffic types** unicast, broadcast, multicast and anycast
- **Document a network** diagrams, inventories, address management and service levels
- **Control change** life cycle, end of support, decommissioning and the change process
- **Monitor and recover** baselines, logs, SNMP, flow data, recovery objectives and sites
- **Explain the core services** dynamic addressing, names, time and remote access
- **Verify on Kali** dig, ss, journalctl and log analysis



CHAPTER 1 · PORTS, PROTOCOLS AND TRAFFIC TYPES

File Transfer and Remote Access

- **FTP** port 21 to control the session, port 20 to move the data, no encryption
- **SFTP** the same file transfer inside Secure Shell, on port 22
- **SSH** an encrypted command line on port 22, the modern default
- **Telnet** port 23, plaintext and legacy; avoid it
- **RDP** port 3389, a full graphical desktop session
- **Rule of thumb** if the name has no S, assume plaintext



CHAPTER 1 · PORTS, PROTOCOLS AND TRAFFIC TYPES

Email, Web and Name Services

- **SMTP** port 25 between servers, port 587 for client submission
- **DNS** port 53: UDP for queries, TCP for zone transfers
- **DHCP** server on port 67, client on port 68
- **HTTP** port 80, stateless
- **HTTPS** port 443, inside Transport Layer Security
- **Troubleshoot names first** names resolve before anything else, so check port 53 early



CHAPTER 1 · PORTS, PROTOCOLS AND TRAFFIC TYPES

Management and Communication Ports

Protocol	Port	Purpose
SNMP	161 UDP	Manager polls a device
SNMP	162 UDP	Device sends a trap
LDAP	389	Directory queries
LDAP over TLS	636	Encrypted directory queries
SIP	5060	Call signalling
SIP over TLS	5061	Encrypted call signalling

Notice the pattern: the protected form always moves to a different port. Port 389 becomes 636, and 5060 becomes 5061.



How Traffic Is Addressed

- **Unicast** one sender to one receiver, the everyday case
- **Broadcast** one sender to every device on the segment
- **Contained** a broadcast stays inside one subnet to limit the noise
- **Multicast** one sender to the group that joined the stream
- **Anycast** one sender to the nearest of many sharing one address
- **Why anycast matters** global name servers and content networks scale on it



DISCUSSION

Which service would you close first on an internet-facing router?

Telnet on port 23 and FTP on port 21 send credentials in clear text, and both have encrypted replacements already: SSH on 22 and SFTP on 22. Then ask which management ports, such as SNMP on 161 or LDAP on 389, genuinely need to be reachable from outside.

Every open port is a decision. Every service you do not need is attack surface you did not have to defend.



CHAPTER 2 · DOCUMENTATION, AGREEMENTS AND SURVEYS

Physical and Logical Diagrams

Diagram	Shows	Answers
Physical	Devices, ports in use, cable runs	Where the cable actually goes
Logical	Addressing, VLAN segments, traffic flow	How the traffic actually moves

One workstation drops: reach for the physical diagram and find the dead port. Everything is slow: reach for the logical diagram and find the route that is too long.



Specialised Diagrams

- **Rack diagram** the unit position of each device, and its power feeds
- **One rack unit** 1.75 inches of vertical space
- **Cable map** cable paths, labels and both termination points
- **Wiring schematic** structured cabling, patch panels and distribution frames
- **Floor plan** equipment rooms, cable tray routes and access points
- **Use the drawing** to plan the change, not only to record it



CHAPTER 2 · DOCUMENTATION, AGREEMENTS AND SURVEYS

Asset Inventory and Address Management

- **Asset record** serial number, location, configuration and owner
- **Software record** version, licence key and installation location
- **Warranties** and service agreements, with their end dates
- **Address management** tracks every static and dynamic allocation in one place
- **Integration** address changes flow into the name system
- **Conflict detection** finds duplicate addresses before your users do



Service Level Agreements

- **What it defines** uptime, response time and resolution time
- **Each additional nine** cuts permitted downtime roughly tenfold
- **Design consequence** uptime targets drive redundancy and failover
- **Internal agreement** between IT and other business units
- **External agreement** with a provider, backed by service credits
- **The catch** every clause you sign has a build cost attached



Wireless Site Surveys

- **Predictive survey** before installation: floor plan plus modelling software
- **Validation survey** after installation: measured signal, noise and throughput
- **Heat map** signal strength, noise floor and channel utilisation
- **Lower band** three non-overlapping channels: 1, 6 and 11
- **Higher band** many more non-overlapping channels, shorter range
- **What the data decides** access point placement and the channel plan



CHAPTER 3 · LIFE-CYCLE AND CONTROLLED CHANGE

Life-Cycle and Firmware Management

- **End of Life** the vendor stops selling the product
- **End of Support** no more patches arrive; this is the security cliff
- **Unsupported equipment** keeps every flaw found afterwards open
- **Update path** download, verify the source, stage, test, deploy
- **Version control** keeps similar devices on one version
- **Rollback** a tested rollback plan, inside a maintenance window



Asset Decommissioning

- **Sanitise first** factory reset and erase the configuration
- **Certificates and accounts** remove certificates, delete stored credentials
- **Physical destruction** the strongest assurance for storage media
- **Degaussing and overwriting** for magnetic media and less sensitive data
- **Environmental duty** certified recycling under electronic waste rules
- **Then the records** update inventory, diagrams and monitoring



CHAPTER 3 · LIFE-CYCLE AND CONTROLLED CHANGE

Controlled Change

- **The problem** uncontrolled change is a leading cause of outage
- **Change Advisory Board** reviews and approves anything that disrupts service
- **Standard change** routine and pre-approved
- **Normal change** planned, tested and reviewed
- **Emergency change** implemented first, reviewed afterwards
- **Every request carries** justification, risk, impact, rollback and result



CHAPTER 3 · LIFE-CYCLE AND CONTROLLED CHANGE

The document you did not update is the one you will trust

- **Four records** the network diagram, the asset inventory, the configuration baseline and the monitoring
- **Skip one** and the next engineer works from fiction
- **Worse than nothing** a diagram that disagrees with reality earns confidence it has not deserved

Make documentation part of the change itself, with a named owner, rather than a chore for later.



CHAPTER 4 · CONFIGURATION AND MONITORING TOOLS

Configuration Management and Backups

- **Production configuration** what the device is running right now
- **Baseline configuration** the approved template for that device type
- **Configuration drift** slow divergence from the baseline, one tweak at a time
- **Compliance checking** compares running settings against policy
- **Backup routes** manual export, scheduled capture or triggered on change
- **Keep three copies** locally, in version control and off site, then test a restore



CHAPTER 4 · CONFIGURATION AND MONITORING TOOLS

Simple Network Management Protocol

- **The model** a manager asks, an agent answers, a database holds the values
- **Object identifiers** name each value that can be requested
- **GET and SET** GET reads a value, SET changes one
- **TRAP** the unsolicited alert when something crosses a threshold
- **Ports** 161 for requests, 162 for traps
- **Authentication** a community string is a plaintext password; use version 3



CHAPTER 4 · CONFIGURATION AND MONITORING TOOLS

Flow Data

- **A flow record** summarises a conversation, not a packet
- **NetFlow** records collected as traffic crosses an interface
- **sFlow** samples packets at intervals, suited to fast links
- **IPFIX** the standard export that grew out of NetFlow version 9
- **What a flow holds** addresses, ports, protocol, byte counts, timestamps
- **The advantage** lower overhead and longer retention than full capture



CHAPTER 4 · CONFIGURATION AND MONITORING TOOLS

Flow Records or Full Capture

Question	Flow records	Full capture
What it holds	Summary of a conversation	Every byte of every packet
Cost	Low storage, long retention	High storage, short retention
Best for	Trends, capacity, floods	Protocol faults, malware detail
Tools	NetFlow, sFlow, IPFIX	Wireshark, tcpdump, port mirroring

Start with flow records for the shape of the day. Move to full capture only to read what was said, and only with authority: packets hold personal data.



CHAPTER 5 · BASELINES, LOGS AND RESILIENCE

Baselines and Metrics

- **A baseline records** bandwidth, latency, error rate and device load
- **Compare** today against the baseline, not against a hunch
- **Threshold alerting** simple to build, fires on fixed limits
- **Anomaly detection** watches the shape of the data instead
- **Trending** turns those records into a capacity forecast
- **Keep it honest** a baseline is only valid until the network changes



CHAPTER 5 · BASELINES, LOGS AND RESILIENCE

Logs and Integration

- **Log aggregation** one searchable repository for every device
- **Syslog** carries source, timestamp and message to a log server
- **Severity** zero is emergency, seven is debug
- **A SIEM** correlates across sources to find the pattern
- **Interfaces** pull logs from cloud services into the same place
- **Automation** can block a source or raise a case on one event



CHAPTER 5 · BASELINES, LOGS AND RESILIENCE

Disaster Recovery Metrics

Metric	Question it answers	What it drives
Recovery Point Objective	How much data may we lose?	Backup frequency
Recovery Time Objective	How long may we be down?	Redundancy and failover
Mean Time To Repair	How fast do we restore service?	Repair process and spares
Mean Time Between Failures	How long before a failure?	Maintenance and refresh

Low numbers cost money. Agree them with the business, do not invent them.



CHAPTER 5 · BASELINES, LOGS AND RESILIENCE

Disaster Recovery Sites

- **Cold site** space, power and connectivity, no equipment
- **Warm site** some equipment in place, data not current
- **Hot site** a live mirror: fastest recovery, highest cost
- **Distance** far enough away to miss the same disaster
- **Latency** close enough to keep replication workable
- **Regulation** can decide where the data is allowed to sit



CHAPTER 5 · BASELINES, LOGS AND RESILIENCE

High Availability Architectures

- **Active-active** every node serves traffic and shares the load
- **Active-passive** a standby waits for a heartbeat to stop
- **Load balancing** spreads requests and steers away from dead nodes
- **Geographic redundancy** survives the loss of a whole region
- **Stretched cluster** spans two sites as a single cluster
- **The bill** faster recovery always costs more capacity



Disaster Recovery Testing

- **The rule** a plan that has never been tested is unproven
- **Tabletop** walk the plan through as a discussion
- **Simulation** perform the recovery tasks away from production
- **Parallel test** run recovery alongside live traffic
- **Full failover** switch everything; the only complete proof
- **Afterwards** document every test and repeat at least once a year



BREAK
10 MINUTES

Back soon: the core services everything leans on, and the commands that verify them.



CHAPTER 6 · CORE SERVICES AND REMOTE ACCESS

Dynamic Addressing

- **The exchange** discover, offer, request, acknowledge: recite DORA from memory
- **From nothing** the client asks from no address at all, to the broadcast address
- **Relay agent** carries the conversation to a server on another subnet
- **Reservation** pins one address to one hardware address
- **Scope options** deliver gateway, name servers and domain
- **Failover** one server stands by, or both share the load

A client accepts the first offer it receives. That is the risk an attacker exploits.



CHAPTER 6 · CORE SERVICES AND REMOTE ACCESS

Automatic Addressing in Version Six

Method	Who assigns the address	Where it fits
Stateless autoconfiguration	The host, from the router advertisement	Simple networks, quick deployment
Stateful DHCPv6	A server assigns and records it	Managed addressing, audit trail
Stateless DHCPv6	Host assigns, server supplies options	Names and settings without addresses
Privacy extensions	Host rotates temporary addresses	Resists long-term tracking

The interface identifier can come from the hardware address, with FF FE inserted in the middle. Privacy extensions rotate it so a device cannot be tracked.



CHAPTER 6 · CORE SERVICES AND REMOTE ACCESS

Name Services

- **Root** thirteen sets of root servers point each query down the hierarchy
- **Authoritative servers** hold the records; resolvers ask on your behalf
- **Records** A and AAAA, CNAME, MX, PTR and TXT
- **Time to live** decides how long a resolver may cache an answer
- **Split horizon** answers internal and external clients differently
- **DNSSEC** signs records, so a forged answer fails validation



Time Synchronisation Services

- **Stratum zero** the reference clock, atomic or satellite based
- **Stratum one** servers connected directly to the reference
- **Lower strata** spread the load away from the reference clocks
- **Use several sources** for redundancy and cross checking
- **What drift breaks** tickets, logs and incident timelines
- **Authenticate it** so a forged source cannot move your clock



Virtual Private Networks

- **Site to site tunnel** joins two offices over a public link
- **Remote access tunnel** serves one user through client software
- **IPsec transport mode** encrypts the payload only
- **IPsec tunnel mode** encrypts the whole packet
- **Full tunnelling** sends everything through the tunnel
- **Split tunnelling** sends only corporate traffic through it



CHAPTER 6 · CORE SERVICES AND REMOTE ACCESS

Remote Access and Device Management

Method	How it reaches the device	When to use it
Console cable	Direct serial connection, out of band	First setup, recovery, no network
Secure Shell	Encrypted command line over the network	Routine work and troubleshooting
Web interface	Browser session, usually encrypted	Simple tasks, less experienced staff
Programmatic interface	Application programming interface	Automation and scale

Every one of these paths is an attack surface. Harden all four, and turn off the ones you do not use.



Verifying services on Kali

- **DNS** `dig bbc.co.uk +short, cat /etc/resolv.conf`
- **DHCP** `cat /var/lib/dhcp/dhclient.leases` shows the lease history
- **Time** `ntpq -p, timedatectl, journalctl -u ntp`
- **SSH** `ss -tnp | grep :22, grep sshd /var/log/auth.log`
- **Services** `ss -tuln` shows everything listening
- **The audit rule** explain every listener or you have a gap



Reading the evidence

- **Failed passwords** `grep 'Failed password' /var/log/auth.log | wc -l`
- **Accepted logins** `grep Accepted /var/log/auth.log`
- **Service ports in use** `ss -tunap | grep -E ':(22|53|123)'`
- **The analyst habit** correlate SSH and RDP times, users and flows
- **Log correlation** one device shows an event; correlation shows the campaign
- **The red flag** an unexpected listening port is an indicator of compromise



QUIZ

Check your understanding

- Open Quiz_Session_03.html in your browser.
- 20 questions, immediate feedback, topic tag on every question.
- Read each explanation; the distractors teach as much as the answer.
- Score 70%+ before moving on.

Every question maps to a session topic, e.g. 3A DNS.



KEY TAKEAWAYS

- **Ports come in pairs** file transfer 21 and 22, Telnet 23 and SSH 22, web 80 and 443
- **Traffic is addressed four ways** unicast, broadcast, multicast or anycast
- **Keep both diagrams current** physical cabling and logical flow; a wrong drawing is worse than none
- **End of Support is the cliff** patch with a rollback ready, and document the change
- **Recovery objectives choose the site** and only a tested plan is real
- **Harden every management path** console, command line, browser and interface



REVISION CHECKLIST

Before next session

- **Learn the port pairs** 21/22, 23/22, 25/587, 53, 67/68, 80/443, 161/162, 389/636, 5060/5061
- **Monitor with flows first** keep flow records long; capture packets only when you must
- **Remember the core services** dynamic addressing, names and time are what everything leans on
- **Run the commands** dig, ss, ntpq and journalctl on any Linux box you can reach
- **Retake the quiz** until you score 70%+ without guessing
- **Then take one habit forward** before you change anything, ask what breaks if it fails



NEXT SESSION

Session 4: Fundamental Security Concepts

- The CIA triad, non-repudiation and the AAA framework
- Security controls by category and functional type
- Zero trust, deception technology and change control
- The NIST Cybersecurity Framework and gap analysis

